3.7 Summary

- Use threat-modelling with STRIDE to identify threats to your API. Select appropriate security controls for each type of threat.
- Apply rate-limiting to mitigate DoS attacks. Rate limits are best enforced in a load balancer or reverse proxy, but can also be applied per-server for defense in depth.
- Enable HTTPS for all API communications to ensure confidentiality and integrity of requests and responses. Add HSTS headers to tell web browser clients to always use HTTPS.
- Use authentication to identify users and prevent spoofing attacks. Use a secure password-hashing scheme like Scrypt to store user passwords.
- All significant operations on the system should be recorded in an audit log, including details of who performed the action, when, and whether it was successful.
- Use ACLs to enforce access control after authentication.

ANSWERS TO EXERCISES

1. c - Rate-limiting should be enforced as early as possible to minimize the resources used in processing requests.
2. b - The `Retry-After` header tells the client how long to wait before retrying requests.
3. d, e, and f - A secure password hashing algorithm should use a lot of CPU and memory to make it harder